Heritage Bank & Trust — Enterprise Technology Context

Platform Overview

Heritage Digital is built as a **hybrid architecture**: the IBM AS/400 remains on-premises; all new microservices run on AWS. The **Banking Integration Hub (BIH)** is the critical adapter layer that owns all AS/400 communication and protects the rest of the platform from legacy coupling.

Banking Integration Hub (BIH)

The BIH is the single gateway between modern services and the AS/400. No service other than BIH may communicate with AS/400 directly.

Integration Method	When Used
FiServ Open Solutions REST API	~60% of operations (account queries, balance, internal transfers, account opening)
IBM MQ (async messaging)	High-reliability async operations (ACH file submission, wire initiation, large batch jobs)
SFTP batch files	Statement generation, legacy reconciliation reports

Critical constraint: All AS/400-bound write operations must be **queued and retried** around batch windows (midnight–4 AM CT, 6 PM CT EOD). The BIH holds operations in an IBM MQ queue during these windows and processes them when the window closes. Customer-facing UIs must show a "processing scheduled" status during batch windows without blocking read access.

Shared Infrastructure

Cloud & Deployment

- **Cloud**: AWS (hybrid — AS/400 on-prem in Heritage's Columbus, OH data center; new services on AWS us-east-2)
- **Network**: AWS Direct Connect between Heritage data center and AWS VPC; encrypted transit
- **Runtime**: Spring Boot 3.2 (Java 21) for backend microservices; deployed as containers on Amazon ECS Fargate
- **IaC**: Terraform; all resources version-controlled; no manual AWS console changes
- **CI/CD**: GitLab CI — lint → unit test → integration test → staging deploy → CAB review → production deploy; **no Friday deployments after 15:00 CT** (SOX)

API Gateway & Security

- **API Gateway**: Kong Gateway (on-prem for internal services) + AWS API Gateway (public-facing)
- **Auth**: Okta OIDC/PKCE for mobile; Okta session-based for web; Okta SAML for internal staff tools
- **MFA**: mandatory for all accounts — SMS OTP or TOTP authenticator app; biometric (FaceID/TouchID) as second factor on mobile
- **mTLS**: enforced on all B2B integrations (BIH ↔ AS/400, Actimize feed, FIS Worldpay callbacks)
- **Session management**: 10-minute inactivity timeout (online banking); 5-minute timeout (mobile)

Audit Service (SOX + BSA Compliance)

- All customer data access events emitted to the **Audit Service** via Kafka
- Immutable append-only audit log stored in DynamoDB → S3 Glacier archive; retained 7 years
- Audit records include: `customerId`, `staffId` (if applicable), action, timestamp, source IP, outcome
- Compliance Officers and Fraud Analysts access audit records via a read-only internal portal

Event Bus

- **Apache Kafka (Amazon MSK)**: domain event bus for asynchronous integration between microservices
- Key events: `account.balance.updated`, `transfer.initiated`, `transfer.settled`, `card.blocked`, `fraud.alert.raised`, `wire.submitted`, `ach.file.submitted`
- NICE Actimize consumes a real-time transaction feed from Kafka for fraud monitoring

Data Layer

- **Amazon RDS PostgreSQL 15** (Multi-AZ): transactional data for services that cannot use AS/400 directly (card management state, notification preferences, service cases)
- **Amazon ElastiCache Redis**: session cache, balance cache (TTL 30 s — AS/400 available balance), idempotency keys for payment operations
- **Amazon DynamoDB**: Audit Service (high-throughput append-only writes), notification delivery state
- **Amazon S3**: statement PDFs, account opening documents, dispute evidence files (encrypted SSE-KMS)

Shared Services (Platform Team)

Service	Responsibility
Banking Integration Hub (BIH)	All AS/400 communication; operation queuing during batch windows; retry with exponential backoff
Audit Service	Immutable PHI/financial data access log (SOX + BSA); Kafka consumer; DynamoDB + S3 Glacier
Notification Service	Email (AWS SES), SMS (Twilio), push (FCM/APNs); customer channel preferences respected
Customer Service	Okta user management, account lockout/unlock, MFA enrollment; profile and preference storage

---

Engineering Standards

- **Language**: Java 21 (Spring Boot 3.2) for backend services; React 18 (TypeScript) for all frontends
- **Testing**: unit ≥ 80%; integration ≥ 60%; all tests run in GitLab CI on every merge request
- **Change management**: all production changes require CAB approval + rollback plan; emergency changes require post-hoc CAB review within 24 hours
- **Secrets**: AWS Secrets Manager; AS/400 credentials, Okta secrets, FIS Worldpay keys rotated quarterly
- **Encryption**: TLS 1.3 in transit; AES-256 SSE-KMS at rest for all S3 data and RDS snapshots
- **Idempotency**: all payment and transfer operations include an idempotency key; duplicate requests return the result of the original operation without re-executing